

Лекция 9. Отравление данных, backdoor-атаки и приватность нейронных сетей

Переносим внимание с манипуляции входом готовой модели на доверие к обучающим данным, весам и интерфейсу предсказаний.

БЕЗОПАСНОСТЬ ML



О чем будем говорить?

Смена вопроса

После обсуждения атак на NLP и LLM полезно сменить фокус: не только «почему модель выполнила постороннюю инструкцию?», но и «кто сформировал её поведение при обучении и что модель раскрывает после развёртывания?»

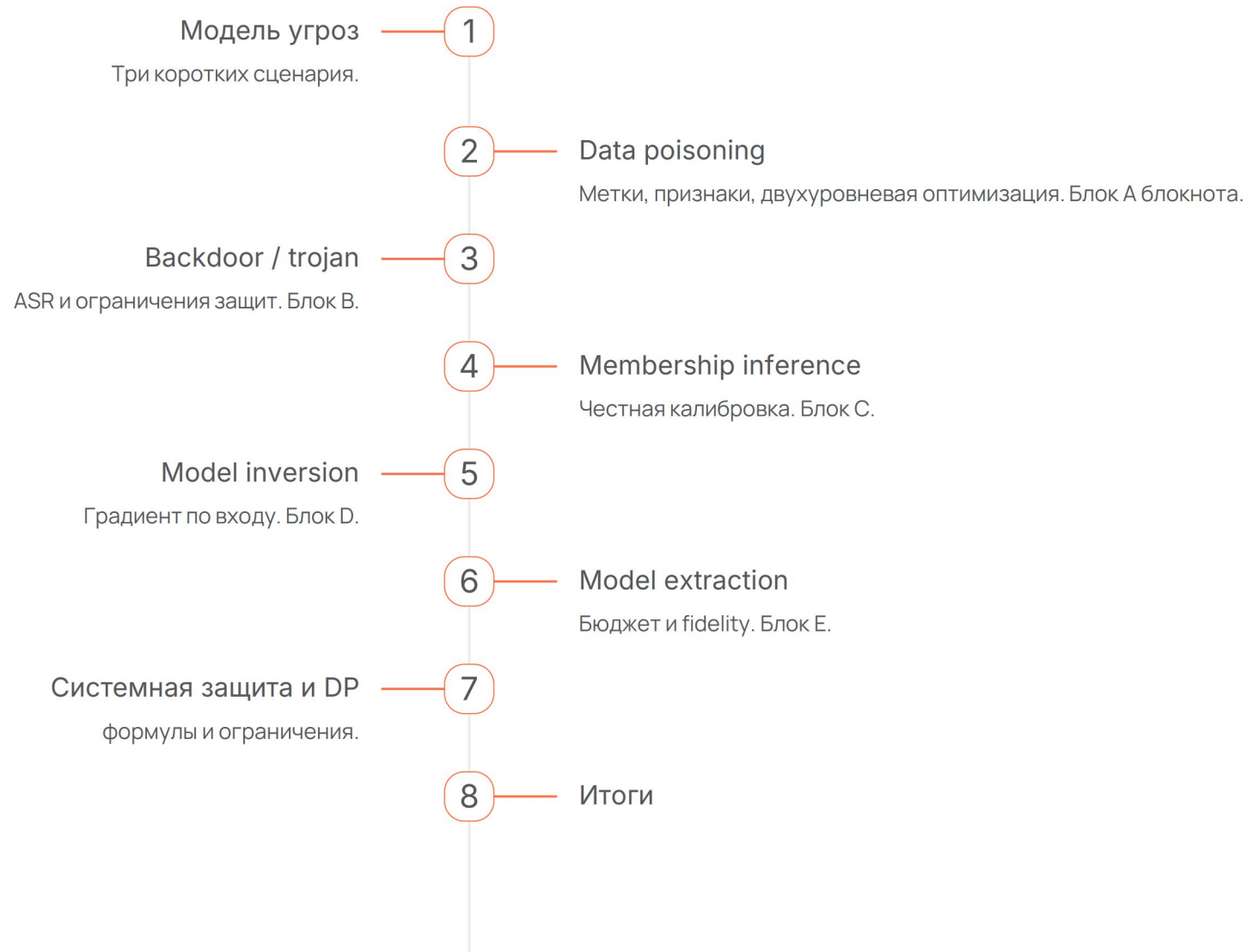
В этой лекции используем небольшие классификаторы, чтобы отделить механизм атаки от сложности современных LLM.

Предполагаемые знания

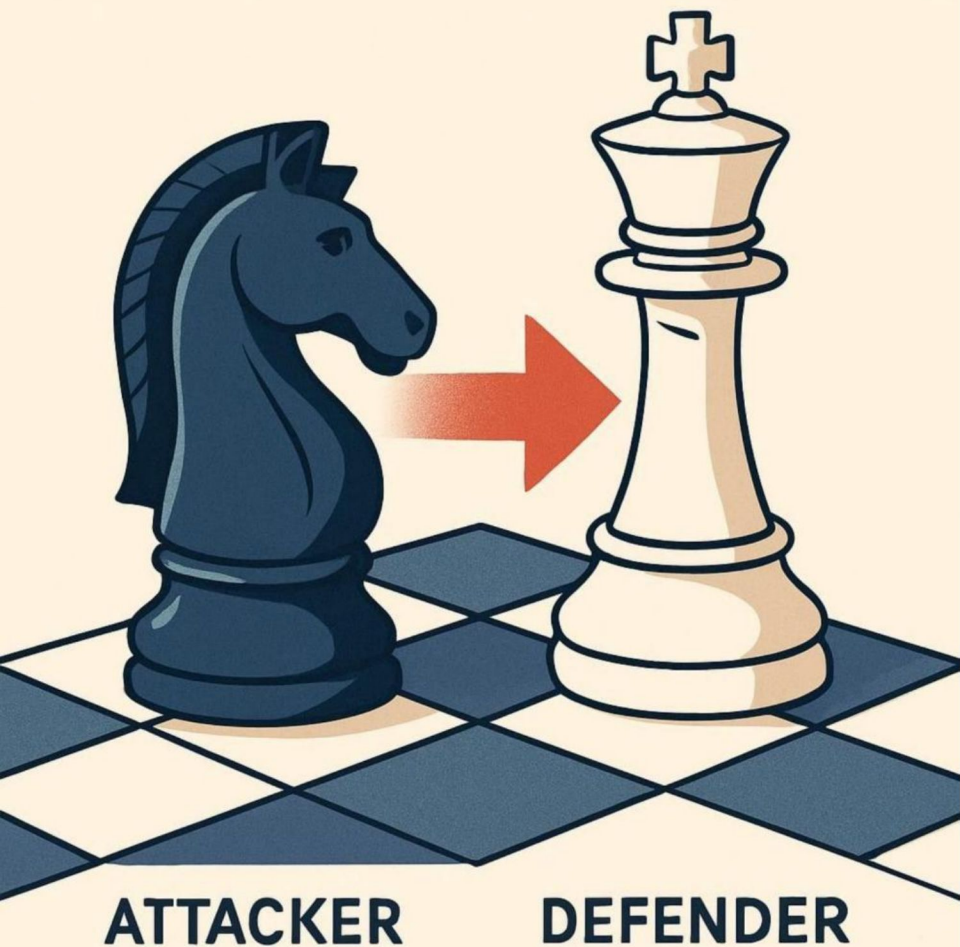
- MLP, softmax, cross-entropy
- Градиентный спуск и переобучение
- Train / validation / test разбиение

Различие между **градиентом по весам** и **градиентом по входу** ?

План лекции



THREAT MODEL



Модель угроз: что разрешено атакующему

В таксономии NIST атаки рассматриваются через **цели нарушителя, его знания, возможности и этап жизненного цикла**. Poisoning относится к вмешательству в обучение, а privacy-атаки направлены на раскрытие информации о данных или модели (NIST AI 100-2e2025).

- ❏ Обозначений white-box и black-box недостаточно: рядом обязательно записываются конкретные доступные операции.

Три стартовых сценария

Подмена разметки

Подрядчик изменил часть меток в train.
Итоговая модель хуже распознаёт
обычные объекты.

Актив: доступность и целостность
результата.

Скрытый триггер

Модель проходит чистый тест, но
изображение с небольшой наклейкой
направляется в один заданный класс.

Актив: условная целостность
поведения.

Информативный ответ

API возвращает вероятности, и
наблюдатель пытается выяснить,
использовалась ли известная запись
при обучении.

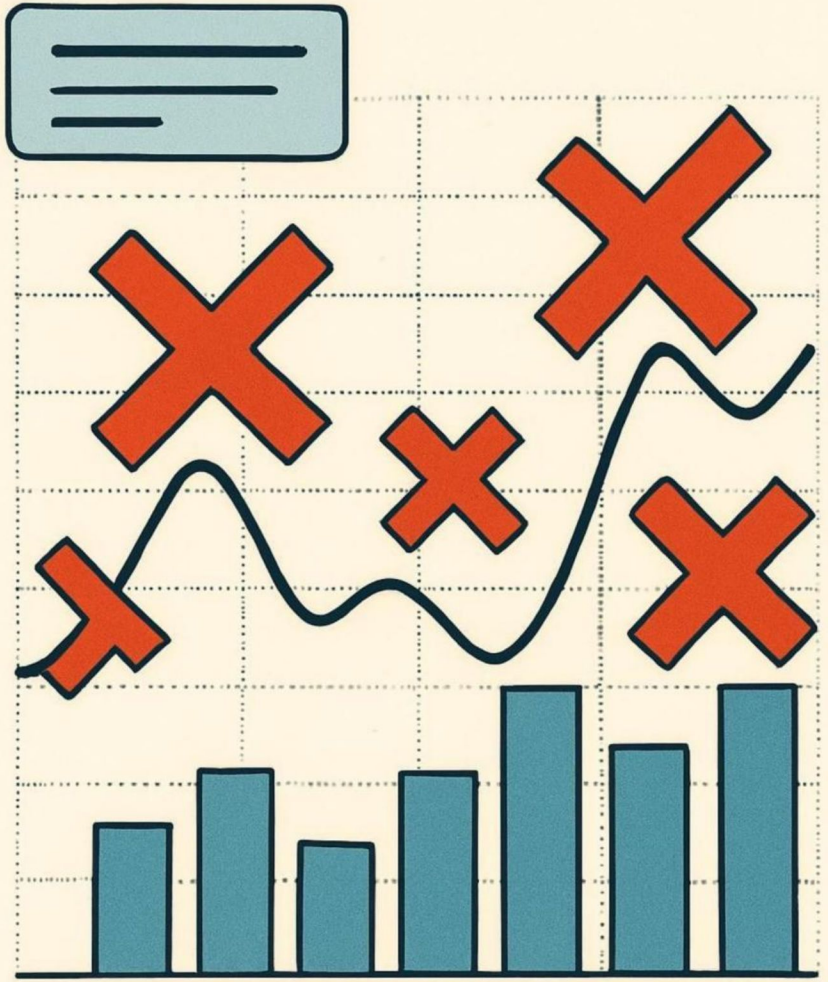
Актив: конфиденциальность факта
участия записи.

Какой актив является защищаемым?

Возможности атакующего: протокол

Опыт	Что разрешено	Чего не получает
Label flipping	Менять часть меток train	Менять test
Backdoor	Менять часть входов и меток train; накладывать триггер при проверке	Подбирать параметры по итоговому test
Membership inference	Знать кандидат (x, y) , получать вероятности, обучить shadow на отдельной выборке	Использовать membership-метки target test для настройки
Model inversion	Знать веса и вычислять градиент по входу	Использовать train-изображения в оптимизации
Model extraction	Посылать входы из public pool, получать ответы в пределах бюджета	Использовать истинные метки pool, веса teacher и test для обучения клона

❏ Таблица описывает лабораторный протокол, а не все возможные варианты атак. Разграничение доступа обеспечивается структурой эксперимента, а не изоляцией процессов.



CORRUPTED DATASET

Data Poisoning: обучение на враждебно изменённой выборке

В supervised learning данные обозначим как $D = \{(x_i, y_i)\}$, а обучение запишем через минимизацию эмпирического риска:

$$\theta(D) = \arg \min_{\theta} \frac{1}{n} \sum_{i=1}^n \ell(f_{\theta}(x_i), y_i) + \lambda R(\theta)$$

При **data poisoning** нарушитель вставляет или изменяет часть обучающих записей. При **model poisoning** его возможности относятся непосредственно к параметрам или процессу обучения (NIST). В этой лекции основной сценарий ограничен подменой записей, а не вредоносным кодом в тренировочном конвейере.

Двухуровневая оптимизация атаки

Пусть $\tilde{D}$ получена заменой не более m записей в D . Для нетаргетной атаки, ухудшающей качество:

$$\max_{\tilde{D} \in C(D, m)} L_{\text{attack}}(\theta(\tilde{D})), \quad \theta(\tilde{D}) = \arg \min_{\theta} L_{\text{train}}(\theta; \tilde{D})$$

Внутренняя задача

Обучается защитник — минимизирует loss на отравленных данных.

Внешняя задача

Выбирается вмешательство — максимизирует ущерб на чистых данных.

Ограничение C должно определять: число изменённых записей, право менять метки, допустимое изменение признаков и доступ к данным. Без этого запись не задаёт воспроизводимого эксперимента.

Для таргетной атаки внешняя функция может минимизировать loss выбранного ошибочного класса на конкретных объектах. Поэтому фраза «атакующий максимизирует loss» верна только после уточнения, *какой loss и на каких данных*.

Виды вмешательства в данные

Availability poisoning

Ухудшение качества на значительной части обычных входов. Label flipping является одним из простых способов воздействия (NIST).

Targeted poisoning

Изменение решения на выбранных объектах или небольшой целевой области при сохранении остального поведения (NIST).

Dirty-label poisoning

Изменение обучающей записи с некорректной для неё меткой. В backdoor-опыте цифра с патчем получает target-метку (NIST).

Clean-label poisoning

Атакующий не меняет метку. Внешне корректная разметка не гарантирует безопасности признаков (NIST).

- ❏ Важная граница: случайный шум разметки и злонамеренный label flipping могут выглядеть одинаково в массиве данных. Намерение и модель угроз определяют термин «атака».

Механизм: один шаг SGD

Вклад отдельной записи в один шаг SGD:

$$\theta' = \theta - \eta g_i, \quad g_i = \nabla_{\theta} \ell(f_{\theta}(x_i), y_i)$$

Замена метки меняет направление g_i , а значит, дальнейшую траекторию оптимизации. В линейном классификаторе с softmax производная cross-entropy по логиту класса k равна:

$$\frac{\partial \ell}{\partial z_k} = p_k - \mathbf{1}[k = y]$$

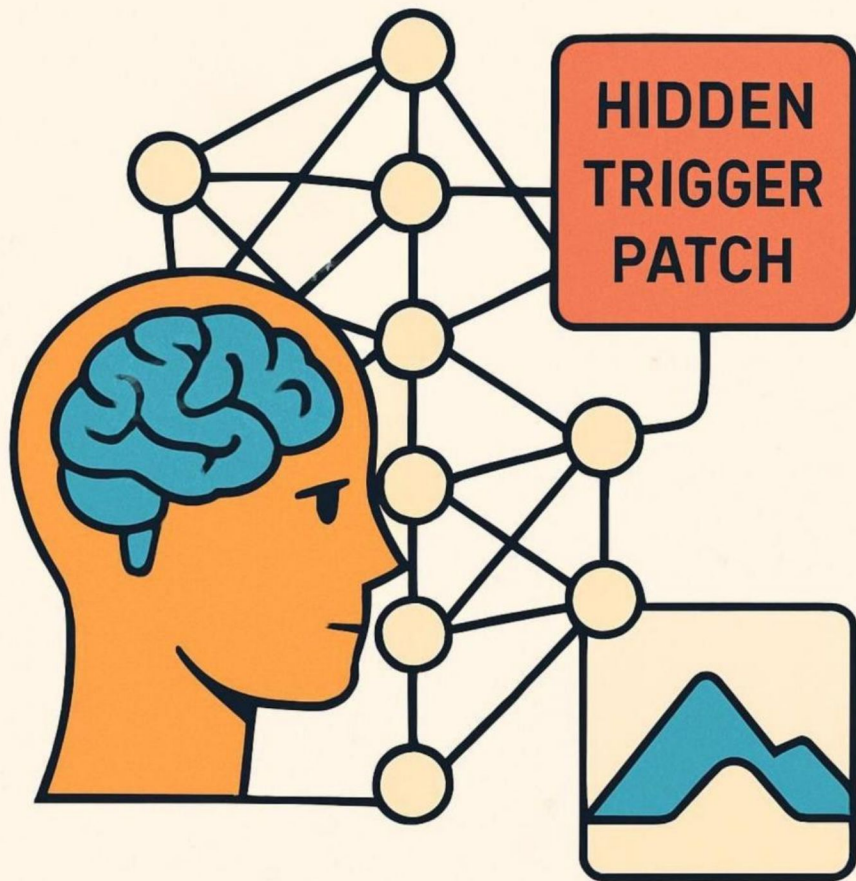
Ключевой вывод

Если верную метку заменить, вычитаемая единица перейдёт к другому классу. Это удобная иллюстрация того, почему отравление не обязано проявляться как аномальная величина входа.

Демонстрация А

Загружаем цифры 8×8, обучаем MLP 64→64→64→10 и сравниваем доли изменённых меток **0**, **0.1**, **0.3**. При сравнении фиксируются исходный split, seed инициализации, число эпох и оптимизатор.

Показываем **clean test accuracy**, а не точность на испорченной разметке. Вопрос: если сеть запомнила случайно изменённые метки, является ли низкий train loss свидетельством качества данных?



Backdoor и Trojan: правильная работа до появления условия

Backdoor-модель может сохранять высокое качество на обычных данных, но выполнять выбранное нарушителем поведение на входах с триггером — именно такое разделение чистого и условного поведения демонстрируется в **BadNets**.

Термин *trojan* часто используется для близких сценариев, однако в каждом случае следует уточнять способ внедрения: данные, веса, архитектура или сторонняя модель (NIST).

Маска, паттерн и формализация

Для изображения определим преобразование с триггером:

$$T_{m,p}(x) = (1 - m) \odot x + m \odot p$$

где $\mathbf{m}$ задаёт область замены, а $\mathbf{p}$ — её значения. В нашем опыте $\mathbf{m}$ выделяет правые нижние 2×2 пикселя, все значения патча равны 1, target-класс $\mathbf{t} = 0$.

Условная цель backdoor

$f_{\theta}^{bd}(x) \approx y$ на обычных входах

$f_{\theta}^{bd}(T(x)) = t$ при наличии триггера

Важное различие

Это не обычная evasion-атака: для backdoor поведение закладывается **при обучении**, а триггер активирует его при применении (NIST).

Один лишь патч на входе чистой модели не доказывает, что модель отравлена.

Метрики backdoor-атаки

Доля отравления: $\rho = m/n$, где n — размер исходной обучающей выборки. В блокноте 90 из 600 записей заменяются, поэтому $\rho = 0.15$.

Clean Accuracy (CA)

$$CA = \frac{1}{|D_{\text{test}}|} \sum_i \mathbf{1}[\hat{y}(x_i) = y_i]$$

Точность на обычных, незатронутых входах.

Attack Success Rate (ASR)

$$ASR = \frac{\sum_{i: y_i \neq t} \mathbf{1}[\hat{y}(T(x_i)) = t]}{\sum_i \mathbf{1}[y_i \neq t]}$$

Доля нетаргетных объектов, перенаправленных в target после патча.

Условный ASR

$$ASR_{\text{cond}} = \frac{\sum_{i \in E} \mathbf{1}[\hat{y}(T(x_i)) = t]}{|E|}$$

Где E — правильно распознаваемые нетаргетные объекты. Отвечает: «сколько корректно классифицированных объектов удалось перенаправить?»

⚠ В отчёте необходимо назвать, какая модель определяет E , и привести размер этого множества. Нельзя незаметно менять знаменатель при сравнении разных моделей.

Контроль clean model + trigger и защиты

Мини-пример для доски

Из 500 test-изображений 50 относятся к target, а 435 из остальных 450 после патча предсказаны как target.

Корректный ASR: $435 / 450 = 96.67\%$

Некорректный ASR: $485 / 500 = 97\%$ — target-объекты не являются успешными перенаправлениями.

Что означает защита

- **Контроль происхождения:** фиксировать поставщика данных, версии, доступ к разметке и артефактам (NIST).
- **Очистка данных:** искать аномалии в исходных или скрытых представлениях; stealthy и clean-label сценарии ограничивают надёжность (NIST).
- **Анализ модели:** реконструкция триггера, анализ активаций, pruning или переобучение (NIST).
- **Инженерная проверка:** тестировать несколько сценариев после fine-tuning; сохранение backdoor после переноса обучения показано в BadNets.

📄 После использования validation для fine-tuning она становится частью обучения этой модели. Итоговое качество и ASR необходимо измерять на остающемся независимом test.

Membership Inference: была ли запись в обучении?

Membership inference определяет, входила ли конкретная запись в обучающую выборку. Постановка с кандидатом и black-box доступом к модели исследуется в работе **Shokri et al.** Сам факт участия может быть чувствительным — например, если набор соответствует определённой медицинской группе (NIST).

Бинарная задача

Для кандидата $z = (x, y)$ вводим скрытую переменную:

$$b = \mathbf{1}[z \in D_{\text{train}}], \quad \hat{b} = A(z, f_{\theta})$$

Классификатор цифр предсказывает метку 0-9; membership-атака предсказывает 0/1 для совершенно другого свойства. Нельзя путать точность исходной модели и точность атакующего.

Score на основе loss

Если обучение уменьшает loss на использованных записях, их распределение score может отличаться от неиспользованных (NIST):

$$s(z) = \log p_{\theta}(y \mid x), \quad \hat{b} = \mathbf{1}[s(z) \geq \tau]$$

В нашем протоколе атакующему известна истинная метка y . Если она неизвестна — это уже другой вариант угрозы.

Shadow-модель и честный протокол

Shadow-подход использует вспомогательные модели, для которых атакующий сам знает состав обучения, и учится различать характер ответов на members и nonmembers (Shokri et al.). В учебном блокноте одна shadow-модель служит только для выбора порога.

01

Разбиение

Выделить target train, target nonmember test, shadow train и shadow nonmember calibration.

02

Обучение

Обучить target и shadow на своих train, не смешивая записи.

03

Калибровка

Выбрать τ по shadow members/nonmembers.

04

Замораживание

Больше не менять порог после просмотра target-результатов.

05

Оценка

Применить порог к target-кандидатам; membership-метки доступны только оценщику.

❌ Плохой протокол выбирает лучший порог на target test и на той же выборке объявляет итоговую ассурасу — он измеряет результат с использованием ответов теста, а не качество заранее заданной атаки.

Метрики membership inference

Основные метрики

Положительный класс здесь означает **member**:

$$TPR = \frac{TP}{TP + FN}, \quad FPR = \frac{FP}{FP + TN}$$

$$BA = \frac{TPR + (1 - FPR)}{2}, \quad Adv = TPR - FPR$$

При фиксированном пороге $BA = (1 + Adv)/2$. ROC-AUC агрегирует качество ранжирования по разным порогам и не обязана совпадать с balanced accuracy рабочей точки.

PPV и базовая частота

$$PPV = \frac{TPR \cdot \pi}{TPR \cdot \pi + FPR \cdot (1 - \pi)}$$

Пример: $TPR = 0.6$, $FPR = 0.1$, $\pi = 0.01$. Тогда **PPV $\approx 5.7\%$** : несмотря на обнаружение 60% members, большинство положительных заключений окажутся ошибочными.

Для privacy-аудита особенно важна способность обнаруживать members при малом числе ложных обвинений (Carlini et al.).

В учебном стенде 400 nonmembers, поэтому минимальный ненулевой шаг FPR равен $1/400 = 0.25\%$. Ноль FP не означает нулевой риск; «правило трёх» даёт верхнюю 95%-оценку порядка $3/400 = 0.75\%$.

Регуляризация и LiRA

Что показывает регуляризация

Блок C сравнивает два режима: длительное обучение без weight decay и более короткое обучение с weight decay. Это **совместное изменение двух факторов**, поэтому наблюдаемое различие нельзя приписывать только одному из них.

Переобучение является полезным сигналом риска, но качественная privacy-оценка не сводится к train/test gap — нужны явно заданная атака и её ошибки (Shokri et al.). AUC ≈ 0.5 для одного baseline означает лишь слабость этого baseline в данном протоколе, а не доказанную приватность модели.

Дополнение: LiRA

LiRA использует отношения правдоподобия, оценивая распределение статистики кандидата при включении и исключении из обучения (Carlini et al.):

$$\Lambda(z) = \frac{p(s(z) \mid z \in D_{\text{train}})}{p(s(z) \mid z \notin D_{\text{train}})}$$

Это более тонкая постановка, чем один общий порог loss. Необходимо понять идею поправки на «сложность» конкретного примера. В блокноте LiRA не реализована, и один shadow нельзя так называть.

Model Inversion: что можно восстановить из поведения модели

Model inversion направлена на восстановление информации о входах, чувствительных признаках или представителях классов по доступу к модели. Confidence-based варианты исследовались в работе **Fredrikson, Jha, Ristenpart**. Смысл восстановленного объекта зависит от постановки: он не всегда является точной записью из train (NIST).

Представитель класса

Найден вход, который модель уверенно связывает с классом. Сам по себе он не устанавливает принадлежность конкретной записи к train (NIST).

Неизвестный атрибут

При известных части признаков и выходе модели оценивается скрытая характеристика. Такая задача связана с attribute inference (NIST).

Конкретная запись

Заявляется восстановление определённого объекта. Это требует отдельной проверки идентичности или степени совпадения, а не только высокой confidence (NIST).

Оптимизация входа при фиксированных весах

Для заданного класса с оптимизируем вход при фиксированных Θ :

$$x^* = \arg \min_x [-\log p_{\theta}(c | x) + \lambda_2 \|x\|_2^2 + \lambda_{TV} TV(x)]$$

Итерация: $x^{k+1} = \Pi_{\mathcal{X}}(x^k - \alpha \nabla_x \mathcal{L})$

Главное отличие от обучения

Θ фиксированы, а оптимизируемая переменная теперь x . Отличие от adversarial perturbation: стартуем со случайного изображения и не требуем близости к заданному исходному объекту.

В настройках: $\lambda_2 = 0.02$, $\lambda_{TV} = 0.05$. TV определяется как сумма средних абсолютных соседних разностей по строкам и столбцам массива 8×8 .

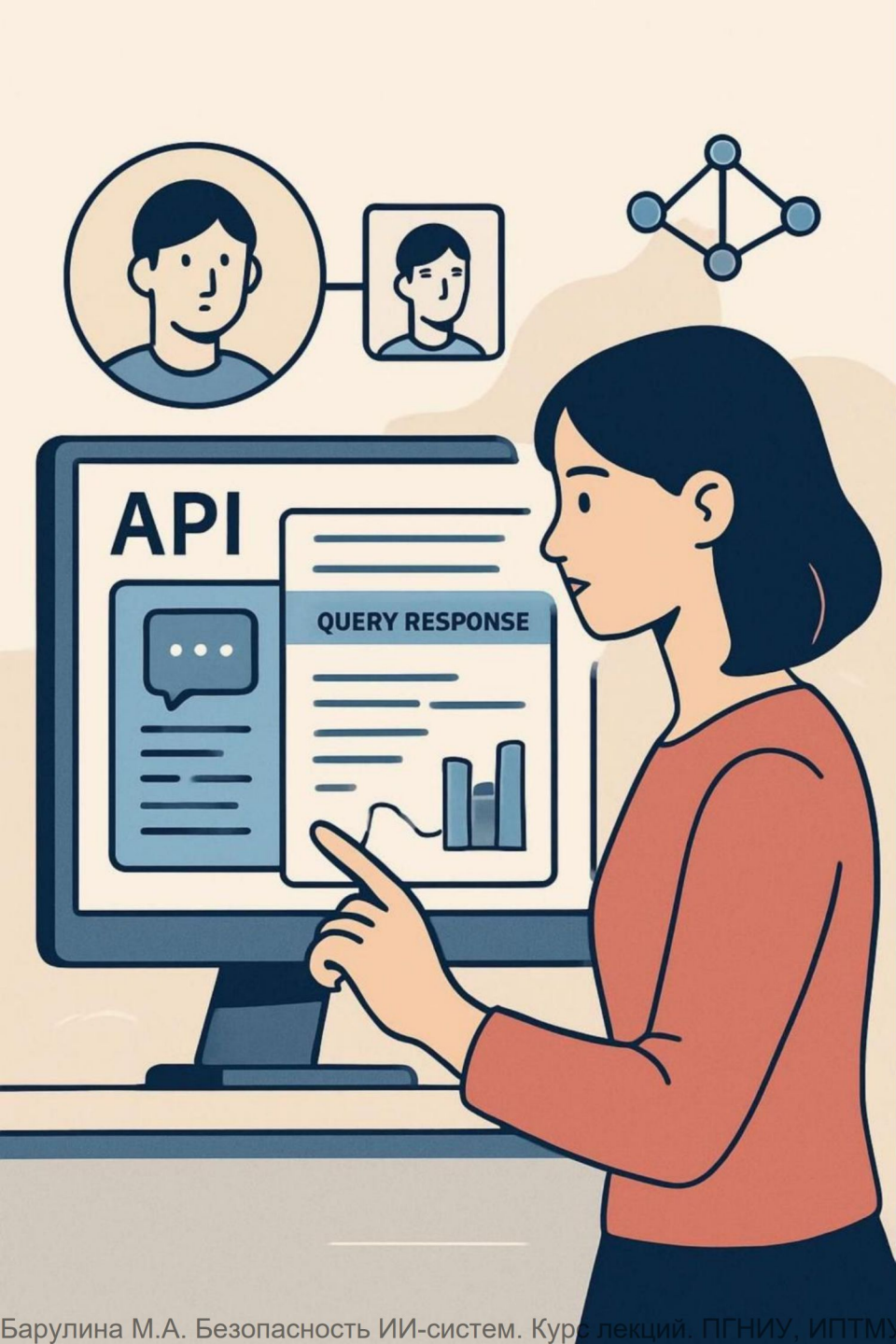
Что показывать на экране

Для классов 0, 3 и 8 запускаются два случайных старта.

Показываются: исходный шум, оптимизированное изображение и ближайший train-пример (доступен только аудитору после завершения оптимизации).

В таблице фиксируются confidence, минимальная MSE до представителей того же класса из train и test. Число кандидатов в двух множествах выравнивается.

❏ Высокая confidence при высокой MSE или неубедительном изображении — содержательный отрицательный результат: целевая функция достигнута, но заявлять точное извлечение данных нельзя.



Model Extraction: копирование функции, а не записей

При model extraction атакующий стремится воспроизвести параметры или функциональность модели по доступным ответам. Query-based извлечение через prediction API исследуется в **Tramèr et al.** В нашей демонстрации копируется поведение, а не точные веса.

$$\phi^* = \arg \min_{\phi} \frac{1}{B} \sum_{j=1}^B H(p_{\theta}(\cdot | x_j), q_{\phi}(\cdot | x_j))$$

$$H(p, q) = - \sum_{k=1}^K p_k \log q_k$$

Teacher задаёт **псевдометки**, а не ground truth. При hard-label доступе вместо распределения остаётся только $\arg \max_k p_{\theta}(k | x)$; запрет вероятностей не устраняет саму возможность model extraction (Tramèr et al.).

Fidelity vs Accuracy и бюджет запросов

Две разные метрики

$$Fidelity = \frac{1}{N} \sum_i \mathbf{1}[\arg \max q_\phi(x_i) = \arg \max p_\theta(x_i)]$$

$$Accuracy_{clone} = \frac{1}{N} \sum_i \mathbf{1}[\arg \max q_\phi(x_i) = y_i]$$

Fidelity отвечает, насколько клон повторяет teacher, **включая ошибки**. Если teacher ошибается в половине случаев, идеально копирующий его student будет иметь fidelity 100%, но accuracy 50%.

Чистота эксперимента

Public pool содержит 500 изображений и не пересекается с train teacher и test. API получает ровно 500 запросов, ответы кэшируются.

Student с бюджетом 50, 150 или 500 получает только соответствующий **префикс кэша**. Суммировать 50+150+500 как отдельные запросы неправильно: одни и те же ответы используются повторно.

Оценка teacher на test производится владельцем стенда, а не атакующим, и не добавляет обучающих ответов клону.

Что ограничивает извлечение



Ограничение числа запросов

Может снижать риск extraction, но эффективность зависит от возможностей нарушителя и требований к полезному API (NIST).



Выявление подозрительной активности

Поведенческий мониторинг и журналы позволяют расследовать злоупотребление, но требуют заранее определённой политики.



Контроль выдаваемой информации

Скрытие confidence не является универсальным решением: label-only ответы тоже могут использоваться для обучения копии (Tramèr et al.).

□ Для прода: составьте политику API — какие ответы нужны законному клиенту, какие лимиты приемлемы и какие журналы позволят расследовать злоупотребление. Политика должна быть связана с бизнес-задачей.

Differential Privacy: что именно обещает гарантия

DP является свойством рандомизированного механизма, ограничивающим изменение распределения его выходов при изменении одного элемента входного набора (Abadi et al.). Для соседних D, D' , отличающихся одной записью:

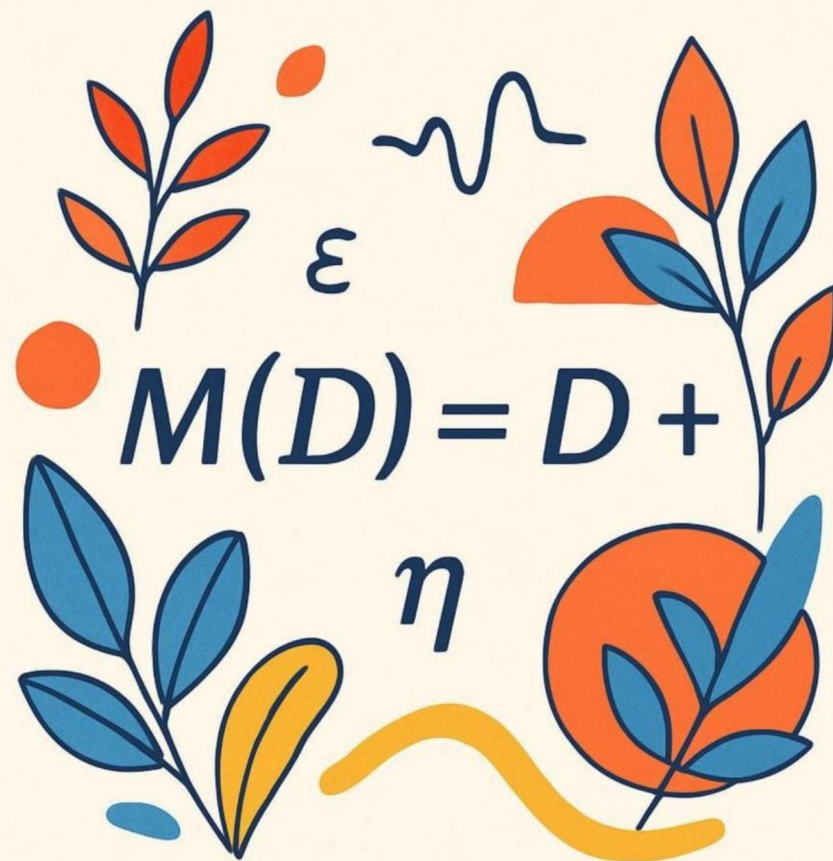
$$\Pr[M(D) \in S] \leq e^\epsilon \Pr[M(D') \in S] + \delta \quad \text{для всех допустимых } S$$

Параметры ϵ и δ

Меньшее ϵ означает более жёсткое мультипликативное ограничение. δ является аддитивным допуском в неравенстве, а не универсальной «вероятностью взлома» (Abadi et al.).

Определение соседства

В отчёте необходимо определить соседство: защита одной записи и защита одного человека с множеством записей являются **разными требованиями**.



DP-SGD: почему одного шума недостаточно

DP-SGD ограничивает вклад каждой записи через per-example clipping, затем добавляет к сумме градиентов калиброванный шум (Abadi et al.):

$$g_i = \nabla_{\theta} \ell_i, \quad \tilde{g}_i = g_i \min\left(1, \frac{C}{\|g_i\|_2}\right)$$
$$\tilde{g} = \frac{1}{L} \left(\sum_{i \in B} \tilde{g}_i + \mathcal{N}(0, \sigma^2 C^2 I) \right), \quad \theta \leftarrow \theta - \eta \tilde{g}$$

Что требует учёта

- Sampling rate и количество шагов
- Параметры шума и noise multiplier
- Композиция обращений к приватным данным
- Применимые этапы подбора модели

Важное ограничение

DP защищает информацию о данных, но **не является гарантией от копирования полезной функции модели**. Различие между data privacy и model privacy подчёркивается в NIST.

В предоставленных блокнотах DP-SGD не реализована: формальная защита рассматривается теоретически, чтобы не выдавать упрощённый код за сертифицированный механизм.

Матрица практического решения

Риск	Что проверять в стенде	Что включать в аудит
Повреждение данных	Доля изменений, clean test accuracy	Происхождение, доступы, версии и независимая разметка
Backdoor	Clean accuracy + ASR + clean-model control	Разные триггеры, адаптивный нарушитель, цена ложных срабатываний
Membership	Shadow calibration, ROC и рабочий порог	Больше nonmembers, несколько атак, применимость DP
Inversion	Confidence и отдельная оценка сходства	Чувствительность атрибутов и корректная идентификация
Extraction	Fidelity, accuracy, фактический бюджет	Лимиты, формат API, поведенческий мониторинг

- ❏ Таблица является предлагаемым планом аудита, а не утверждением о достаточности мер. При выборе защиты нужно понимать, какую возможность нарушителя она ограничивает, и проверить, не разрушена ли полезная функция системы.

Результаты демонстрации: baseline и poisoning

Ниже приведён один контрольный прогон преподавательского блокнота с фиксированными настройками. Это результаты именно учебного стенда, не значения из статей и не усреднение по нескольким seed.

Чистая MLP (baseline)

Train accuracy: **1.000**

Validation: **0.9543**

Test: **0.960**

Зафиксирован рабочий baseline.

Label flipping 10%

Clean test accuracy: **0.832**

В данном режиме повреждение меток ухудшило качество.

Label flipping 30%

Clean test accuracy: **0.660**

Более высокая доля отравления — более значительное падение.

Результаты демонстрации: backdoor

Backdoor 15%

Clean accuracy: **0.960**

ASR: **0.9667** на 450 объектах

Чистая точность не выявила условное поведение.

Clean model + тот же патч

ASR: **0.000**

Triggered accuracy: **0.742**

Патч искажает вход, но не даёт того же перенаправления в target.

Стирание известного патча

Clean accuracy: **0.962**

ASR: **0.000**

Сильное знание позиции триггера помогло в данном опыте.

Чистое fine-tuning

Clean accuracy: **0.954**

ASR: **0.9289**

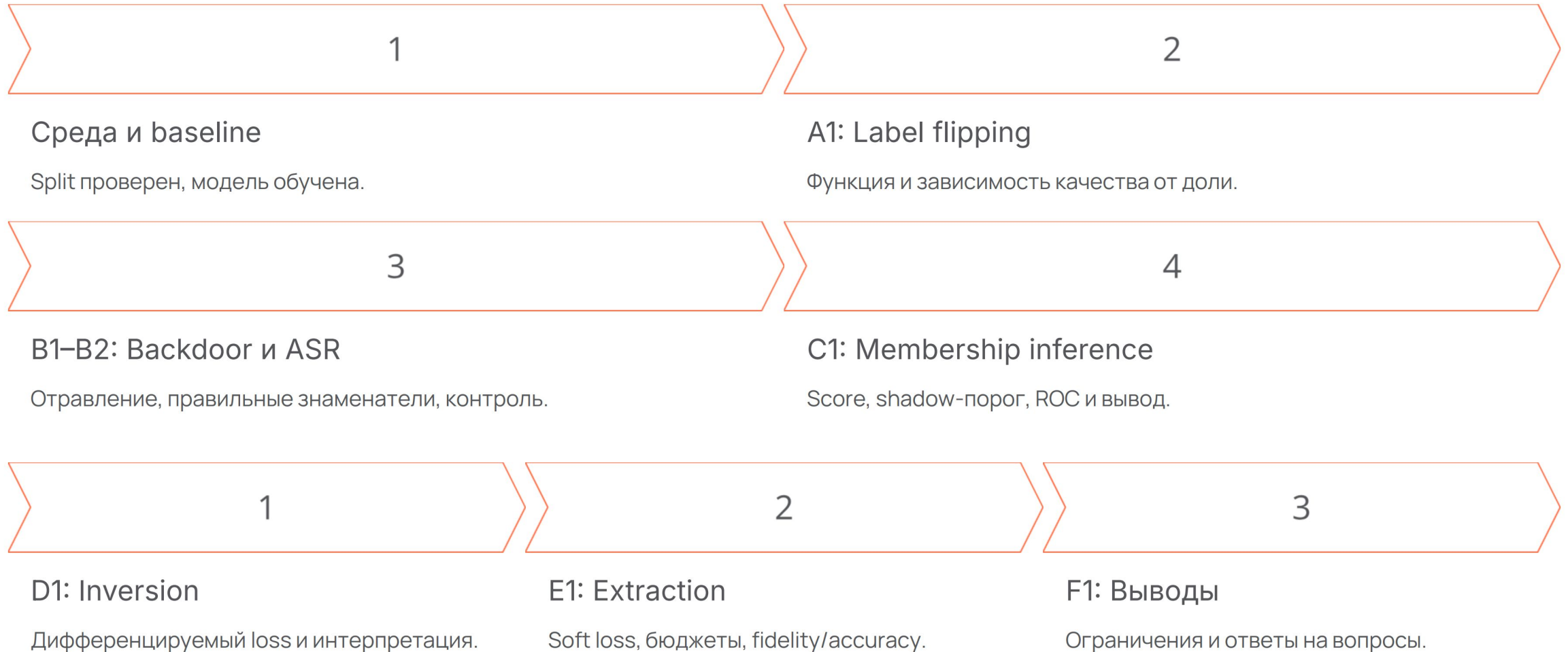
Выбранного дообучения оказалось недостаточно для удаления backdoor.

Результаты демонстрации: MIA, inversion, extraction

Опыт	Результат	Корректный вывод
MIA: длительное обучение	AUC 0.6716; BA 0.7075; FPR 0.585	Baseline различает группы, но рабочая точка даёт много FP
MIA: регуляризованный режим	AUC 0.6183; BA 0.6213; FPR 0.6975	Агрегатные метрики улучшились, но FPR отдельно не снизился
Inversion	Confidence от 0.99985; nearest-train MSE $\approx$ 0.114–0.163	Максимизация уверенности $\neq$ восстановление точной записи
Extraction, 500 запросов, soft	Fidelity 0.962; accuracy клона 0.950	Клон приближает teacher без исходных меток query pool
Extraction, 500 запросов, hard	Fidelity 0.948; accuracy клона 0.938	Отсутствие вероятностей не исключило копирование

Особенно важны два неоднозначных результата: регуляризация уменьшила AUC и advantage, но не FPR на отдельно откалиброванной рабочей точке; высокая confidence у inversion не дала доказательства извлечения конкретной записи.

Лабораторная работа: структура и этапы



Типичные ошибки

Poisoning без бюджета

«Изменили немного данных» не позволяет воспроизвести эксперимент. Нужен точный числитель и знаменатель.

ASR на всех классах

Target-примеры ошибочно засчитываются как успешные перенаправления.

MIA с тестовой калибровкой

Атакующий использовал правильные membership-ответы итогового теста.

Inversion без проверки

Уверенное предсказание ошибочно объявляется восстановлением персональной записи.

Extraction с ground truth

Student обучается на истинных метках, а опыт выдаётся за копирование через API.

«Приватность доказана»

Неудача одной атаки подменяет формальную гарантию или полноценный аудит.

Вопрос

«Мы получили API классификатора и запись пациента. Хотим узнать, была ли она в обучении; затем восстановить неизвестный признак; затем обучить замену сервиса. Почему это три разных эксперимента?»

три разных цели, три модели доступа и три набора метрик
(membership inference, inversion и extraction.)



Итог лекции

Безопасность модели нельзя свести к одной тестовой accuracy

Происхождение обучения

Проверяйте поставщика данных, версии, доступ к разметке. Целостность данных — необходимое, но не достаточное условие.

Условное поведение

Clean accuracy не выявляет backdoor. Необходимы отдельные проверки с триггером и контрольная чистая модель.

Раскрытие информации

Membership inference, inversion и extraction — три разных угрозы с разными метриками и моделями доступа.

Возможность копирования

Ограничение вероятностей не устраняет model extraction. Политика API должна быть связана с бизнес-задачей.



Формальная гарантия (DP) и эмпирическое снижение риска — разные вещи. Неудача одной атаки не является доказательством приватности модели.